

현대엔지니어링 전사 AI 보안 포털

KYRA AI Guardrail 기반 엔터프라이즈 AI 거버넌스

목차

I. 솔루션 개요

II. 시스템 아키텍처

III. 접근통제 — RBAC / ABAC

IV. AI 보안 엔진

V. RAG · Agentic AI 보안

VI. 운영 · 연동 · 보안 하드닝

I. 솔루션 개요

전사(全社) 단일 AI 보안 게이트웨이

솔루션 개요

전사 AI 보안 포털

KYRA AI Guardrail은 사내 모든 LLM·AI 에이전트 트래픽이 통과하는 **단일 보안 게이트웨이**로, 전사 차원의 AI 거버넌스를 제공합니다.

-  **프롬프트 인젝션 방어** — Jailbreak 및 명령 탈취 차단
-  **데이터 유출 방지 (DLP)** — PII·기밀정보 실시간 탐지·마스킹
-  **접근통제** — RBAC + ABAC 듀얼 정책 엔진
-  **RAG 보안** — 분류등급 기반 지식베이스 격리
-  **Agentic AI 보안** — 에이전트 Tool 호출 권한 통제
-  **감사·컴플라이언스** — 전 요청 감사로그 및 정책 추적

전사 적용 모델

부서·시스템 무관 단일 통제 평면

보호 대상 (Workload)

- 사내 AI 챗봇 / 어시스턴트
- 업무 자동화 AI 에이전트
- RAG 기반 사내 지식검색
- 외부 LLM API 호출 (OpenAI 등)
- 사내 자체 호스팅 모델

통제 평면 (Control Plane)

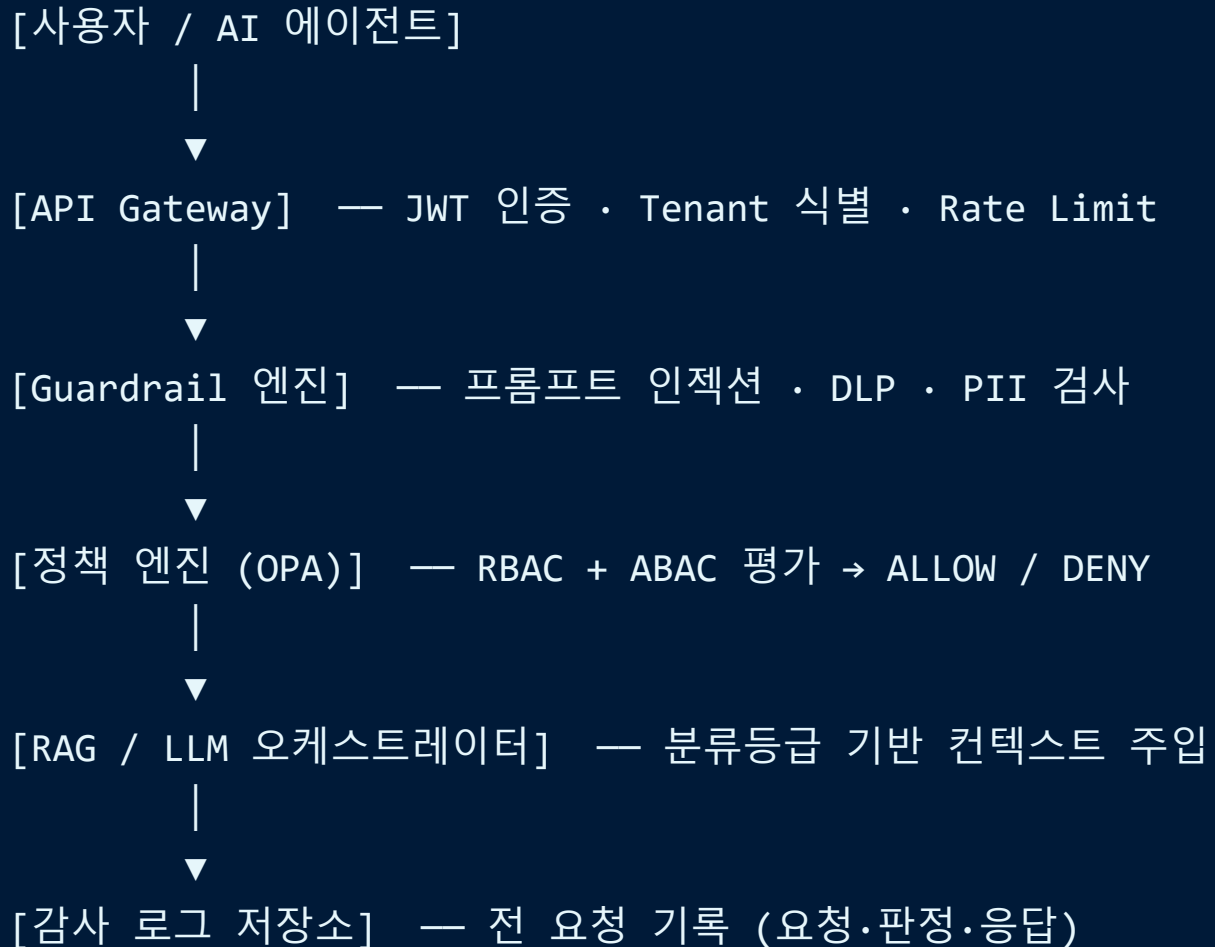
- 모든 트래픽 **단일 게이트웨이** 경유
- 부서별 **Multi-Tenancy** 격리
- 중앙 정책 콘솔에서 일괄 관리

II. 시스템 아키텍처

컨테이너 기반 마이크로서비스

시스템 아키텍처

요청 처리 데이터 흐름



핵심 구성요소

계층	구성요소	역할
게이트웨이	API Gateway	인증.테넌트 식별.라우팅.레이트리밋
보안 엔진	Guardrail Engine	인젝션 방어.DLP.PII 탐지
정책 엔진	OPA (Open Policy Agent)	RBAC/ABAC 정책 평가
지식베이스	Milvus (벡터 DB)	임베딩 저장.유사도 검색
객체 스토리지	MinIO	원문 문서.첨부 저장
세션/캐시	Redis	세션.정책 캐시.레이트리밋
관리 콘솔	Admin Console	정책.사용자.감사로그 관리

배포 토폴로지

컨테이너 오케스트레이션

- **Docker Compose 기반 33개 컨테이너** 단일 스택 배포
- **On-Premise / Cloud / 하이브리드** 전 환경 지원
- 마이크로서비스 단위 **수평 확장(Scale-out)** 가능
- 폐쇄망(에어갭) 환경 배포 지원 — 외부 의존성 최소화

배포 특성: 모든 구성요소가 컨테이너화되어 있어 현대엔지비 내부 인프라(사내 K8s/VM)에 그대로 이식 가능하며, 데이터는 외부로 유출되지 않습니다.

III. 접근통제

RBAC + ABAC 듀얼 정책 엔진

RBAC 기반 역할 제어

Role-Based Access Control

요청 처리 흐름

1. ♦ **요청 수신** — 사용자/에이전트가 문서 조회·Tool 호출 요청
2. ♦ **역할 추출** — Gateway가 JWT 토큰에서 role·tenant 확인
3. ♦ **정책 평가** — OPA에서 `role : resource` 권한 검사
4. ♦ **판정** — 허용(✓) / 거부(X) + 감사로그 기록

RBAC 역할 · 권한 매트릭스

역할	공개	내부	기밀	제한	Tool 호출
Admin	✓	✓	✓	✓	전체
Manager	✓	✓	✓	X	제한
Power User	✓	✓	X	X	지정
User	✓	✓	X	X	읽기
Viewer	✓	X	X	X	없음

5단계 역할 체계로 부서·직급별 최소권한(Least Privilege) 원칙을 강제합니다.

ABAC 기반 속성 제어

Attribute-Based Access Control

동적 정책 평가

[요청] → [속성 추출] → [OPA ABAC 정책] → [ALLOW / DENY]

속성	설명	값 예시
doc.classification	문서 분류등급	public · internal · confidential · restricted
user.role	사용자 역할	admin · manager · user · viewer
user.tenant_id	테넌트 격리	부서별 데이터 완전 분리
agent.action	에이전트 동작	read · write · tool_call · export
context.time	시간대 접근 제어	업무시간 기반 제한 (옵션)

문서 분류 · 접근 정책

4단계 분류등급 체계

분류등급	정의	접근 범위
Public	공개 문서	전 사용자
Internal	사내 문서	내부 임직원
Confidential	기밀 문서	관리자·인가된 사용자
Restricted	제한 문서	관리자 전용

정책 관리 콘솔

-  비개발 운영팀도 **UI 매트릭스**로 정책 설정
-  역할 × 분류등급 교차 권한을 체크박스로 제어
-  변경사항 **즉시 반영**, 전 접근 감사로깅

IV. AI 보안 엔진

프롬프트 인젝션 방어 · DLP

프롬프트 인젝션 방어

Jailbreak / 명령 탈취 차단

다층 탐지 파이프라인

1. **패턴 기반 탐지** — 알려진 인젝션·탈옥 시그니처 매칭
2. **의미 기반 탐지** — 시스템 프롬프트 무력화 의도 분석
3. **컨텍스트 격리** — 사용자 입력과 시스템 명령 분리 처리
4. **출력 검증** — 응답 단계에서 정책 위반 재검사

입력(Input)·출력(Output) **양방향 검사**로, 우회 프롬프트가 모델에 도달하거나 모델이 정책 위반 응답을 반환하는 것을 모두 차단합니다.

데이터 유출 방지 (DLP)

PII · 기밀정보 실시간 통제

탐지 대상

- **개인정보(PII)** — 주민등록번호, 연락처, 이메일, 계좌번호
- **사내 식별자** — 사번, 사업자번호, 프로젝트 코드
- **기밀 키워드** — 분류등급 문서 내 민감 용어

처리 방식

- **◆ 마스킹** — 민감 토큰 비식별화 후 처리
- **◆ 차단** — 정책 위반 요청 즉시 거부
- **◆ 경고** — 운영팀 알림 + 감사로그 적재

V. RAG · Agentic AI 보안

지식베이스 격리 · 에이전트 권한 통제

RAG 보안 아키텍처

분류등급 인지 검색 (Classification-Aware Retrieval)

검색 파이프라인

1. 문서 수집 시 **분류등급 메타데이터** 부착
2. 임베딩 생성 → **Milvus** 벡터 DB 저장 (원문은 **MinIO**)
3. 검색 시 **요청자 권한으로 후보 필터링**
4. 인가된 문서만 LLM 컨텍스트로 주입

권한이 없는 문서는 검색 결과·컨텍스트에서 **원천 제외**되어,
RAG 응답을 통한 기밀정보 간접 유출을 차단합니다.

Agentic AI 보안

에이전트 Tool 호출 통제

통제 메커니즘

- **Tool 권한 화이트리스트** — 역할별 호출 가능 Tool 지정
- **동작 단위 정책** — `read` / `write` / `tool_call` / `export` 개별 통제
- **테넌트 경계 강제** — 에이전트는 소속 테넌트 데이터만 접근
- **체인 추적** — 다단계 에이전트 호출 전 구간 감사로깅

권한 평가 예시

- **Admin** — 전체 Tool 호출 가능
- **Power User** — 지정된 Tool만 호출
- **User** — 읽기 계열 Tool만 호출
- **Viewer** — Tool 호출 불가

VI. 운영 · 연동 · 보안 하드닝

관리 콘솔 · API · 감사

관리 콘솔

중앙 집중 운영 관리

메뉴	기능
Dashboard	접근 패턴·분류 분포·감사 이벤트 현황
Documents	문서·분류등급 관리
Access Policies	역할 × 분류등급 권한 매트릭스
Users	사용자·역할·상태 관리
Audit Logs	접근·변경 이력 조회 및 내보내기
Agents	AI 에이전트 등록·권한 관리
Settings	테넌트별 정책·환경 설정

REST API · 시스템 연동

표준 API 기반 통합

- **REST API** — `/api/v1` 표준 엔드포인트 체계
- **OpenAPI 3.0 명세** — Swagger UI(`/api/docs`)로 탐색·테스트
- **세션 / 토큰 인증** — 쿠키 세션 + JWT 지원
- **페이지네이션·필터링** — 대규모 데이터 조회 표준화
- **감사로그 내보내기** — CSV / JSON 포맷 익스포트

표준 REST·OpenAPI 인터페이스로 현대엔지비 사내 SSO·SIEM·ITSM 등 기존 시스템과 손쉽게 연동됩니다.

보안 하드닝

다층 방어 적용

전송·세션 보안

- HTTPS / **HSTS** 강제
- 세션 쿠키 `HttpOnly` · `Secure` · `SameSite=strict`
- **Redis** 기반 세션 저장소
- **CSRF** 토큰 검증

애플리케이션 보안

- **CSP** 콘텐츠 보안 정책
- **CORS** 화이트리스트 제어
- **Rate Limiting** (IP·계정 단위)

보안 헤더 일괄 적용 (HSTS, CSP, CORS, X-Frame-Options, X-Content-Type-Options, X-XSS-Protection)

감사 · 컴플라이언스

전 요청 추적성 확보

- 모든 요청의 **요청.정책판정.응답** 3요소 기록
- 사용자.에이전트.테넌트.동작.결과 단위 조회
- 기간.동작.사용자별 **필터 검색**
- **CSV / JSON 내보내기**로 외부 감사 대응
- 무결성 보존을 위한 중앙 단일 로그 저장소

기술 사양 요약

<5ms

정책 평가 지연

<200ms

게이트웨이 처리 지연

>99.5%

위협 차단율

33

컨테이너 구성

Secure AI. Empower Enterprise.

현대엔지니어링 전사 AI 보안 포털